

ONLINE BOOKSTORE

An E-Commerce Platform for Buying and Selling Books Online

Phase 2: Design

Validation Specification (Phase 2 Update)

Members	Anagha N (PES1UG24CS058) Manasvi B (PES1UG24CS261) Meda Sahasra Siri (PES1UG24CS267) Monika (PES1UG24CS274)
Course	Software Engineering
Technology Stack	MERN (MongoDB, Express.js, React, Node.js)
Repository	https://github.com/Ana-9211/Software-Engineering-Project-
Based on	Phase 1 Requirements (unchanged)
Document Version	1.0 (Phase 2 draft for team review)

Contents

1. Introduction and Baseline	3
1.1 Purpose	3
1.2 What stays and what is added	3
1.3 Planning level	3
1.4 Identifiers	3
2. Validation Methodology (Updated)	4
2.1 Principles	4
2.2 Test levels and what each validates	4
2.3 Environments and data	4
2.4 Traceability maintenance	4
2.5 Entry and exit criteria (from Phase 1, unchanged)	5
3. Architecture-Based Validation	6
3.1 Validation of each architecture component	6
3.2 Module-level validation focus	6
4. Design Validation	8
4.1 Module interface validation	8
4.2 API contract validation	9
4.3 Database constraint validation	9
4.4 Authorization boundary validation	10
4.5 External service integration validation	10
4.6 UI design validation	11
5. Updated Requirements Traceability Matrix	12
6. Test Case Catalogue	15
7. Security Validation	18
7.1 Scope and approach	18
7.2 Security test cases	18
7.3 Abuse and negative cases summary	20
8. API Validation	21
8.1 Approach	21
8.2 Test data	21
8.3 Endpoint test table	22
9. Performance Validation	28
9.1 Approach	28
9.2 Tests	28
9.3 Result recording	28
10. Design Acceptance Criteria	29
11. Assumptions and Open Items	30

1. Introduction and Baseline

1.1 Purpose

This document updates the Phase 1 Validation Specification (docs/phase-1/Phase1-SRS-and-Validation-Spec.md, Section 9) using the Phase 2 Architecture and Software Design documents. It states how each architectural component, interface, API endpoint, database constraint and security control will be validated, extends the Requirements Traceability Matrix (RTM) with the design columns, and gives the criteria for deciding that the design is ready for Phase 3.

1.2 What stays and what is added

Item	Status
Requirements FR-01 to FR-30, VFR-01 to VFR-15	Unchanged from Phase 1
Use cases UC-01 to UC-25 and the six actors	Unchanged from Phase 1
Phase 1 test case IDs TC-FR-nn and TC-VFR-nn	Kept as parent test cases; Section 6 adds their planned checks
Phase 1 RTM columns (use case, actors, test case)	Kept; Section 5 adds architecture component, design module and API columns
Phase 1 entry and exit criteria	Kept (Section 2.5)
New in Phase 2	Architecture-based validation (3), design validation (4), extended RTM (5), test case catalogue (6), security validation (7), API validation with TC-API-nn (8), performance validation with PT-nn (9), design acceptance criteria (10)

1.3 Planning level

Nothing in this document has been executed. There are no test results, coverage figures, performance numbers or scan results. Every statement describes what will be done, how, and what result will count as a pass. Tools are candidates; the final choice is made in Phase 3. Numbers such as 100 users, 500 ms and 3 s are the Phase 1 requirement values, not measurements.

1.4 Identifiers

Prefix	Meaning
TC-FR-nn, TC-VFR-nn	Parent test case of one requirement (Phase 1)
TC-API-nn	Test group for endpoint API-nn
ST-nn	Security test
PT-nn	Performance or availability test
DA-nn	Design acceptance criterion
AC, BM, FM, I, S, D, A	As defined in the Architecture document

2. Validation Methodology (Updated)

2.1 Principles

1. **Trace first.** Every test case belongs to at least one requirement, and every Must requirement has at least one test case.
2. **Test where the risk is.** Business rules are tested as unit tests; contracts between parts are tested at their boundaries; user flows are tested end to end; non-functional requirements are tested with the tool made for them.
3. **Negative cases are required.** Each endpoint and each rule has tests for invalid input, missing data, wrong user, wrong role and boundary values, not only the success path.
4. **No real card data and no real emails in tests.** The gateway runs in test mode and tests use a fake gateway and fake mailer.
5. **Repeatable.** Tests create their own data from seed scripts and run against a clean database.

2.2 Test levels and what each validates

Level	Validates	Architecture and design elements	Candidate tools
Unit	Business rules in one service or function	BM services (AC-03), utilities	Jest
Repository and integration	Queries, indexes, constraints, transactions, module-to-module calls	AC-04, AC-05, interfaces I-03 to I-24	Jest with a test MongoDB replica set
API (contract and behaviour)	Every endpoint: status codes, bodies, validation, access control	AC-02, wire contract	Supertest or Postman collection, OpenAPI validator
Adapter contract	Payment and email adapters against their interface	AC-06, AC-07, I-11, I-12	Jest with the fake and, for the demo, the sandbox
UI component and end-to-end	Screens, flows, route guards	AC-01, screens S-01 to S-30	React Testing Library, Cypress or Playwright
Non-functional	Performance, accessibility, compatibility, availability	VFR-01 to VFR-03, VFR-09 to VFR-12	k6, Lighthouse, browser matrix, uptime monitor
Security	Authentication, authorization, injection, XSS, CSRF, abuse, dependencies	AC-01 to AC-07	Supertest, OWASP ZAP, manual probes, dependency audit
Acceptance	Use case walkthroughs by the team	All use cases	Manual script per use case

2.3 Environments and data

Item	Plan
Local test environment	MongoDB as a single-node replica set (needed for transactions), fake payment gateway, console mailer, rate limits relaxed only where a test needs it
Validation environment	The deployed environment (provider TBD) with the gateway in test mode; used for security scans, performance tests and the availability window
Test data	Seed script creating categories, 3 sellers, 20 customers, 1 administrator and about 1,000 approved books (more for PT-06); orders created by tests
Accounts	One account per role for authorization tests, plus a second customer and a second seller for ownership tests
Time control	Tests that depend on 15 minutes (lockout, reservation hold), 30 minutes or 60 minutes use an injectable clock rather than waiting

2.4 Traceability maintenance

The RTM in Section 5 is generated from the endpoint table, module table and screen table, and a script checks that no requirement, use case, endpoint or module is left without a counterpart (DA-01 to DA-04). In Phase 3 the "Design / Code" and result columns are completed from the test reports.

2.5 Entry and exit criteria (from Phase 1, unchanged)

Criterion	Definition
Entry	The requirement is approved, has a unique ID and has a verification method
Exit	All Must requirements verified as met; all Should requirements verified or formally deferred with justification; no open critical or high severity defects
Defect handling	Defects are recorded with severity and the affected requirement ID

3. Architecture-Based Validation

3.1 Validation of each architecture component

Component	What is validated	How	Test cases
AC-01 React SPA	Screens show the data and states the use cases need; route guards hide screens by role; responsive layout from 360 to 1920 px; accessibility; browser support; no raw HTML rendering	Component tests, end-to-end flows for the purchase, seller and admin journeys, viewport tests, Lighthouse, browser matrix, lint rule against <code>dangerouslySetInnerHTML</code>	TC-VFR-10, TC-VFR-11, TC-VFR-12, TC-VFR-06, TC-FR-04 to TC-FR-10
AC-02 REST API Layer	Middleware order (CSRF, authentication, role, validation, rate limit); uniform error body; status codes; security headers	API tests for every endpoint; middleware unit tests; header checks	TC-API-01 to TC-API-61, TC-FR-29, TC-VFR-05, TC-VFR-06, TC-VFR-15
AC-03 Business Service Layer	Business rules in the module table (Section 3.2), including the stock reservation lifecycle	Unit tests with fake repositories and adapters; integration tests	TC-FR-01 to TC-FR-30
AC-04 Data Access Layer	Filters, sorting, pagination, owner filters, duplicate-key mapping, use of sessions	Repository tests on a test database	TC-FR-04 to TC-FR-06, TC-FR-30
AC-05 MongoDB Database	Indexes (including the search indexes and their use in query plans), unique keys, TTL index, schema validators (stock, reserved), transaction rollback, GridFS image storage, backup and restore	Constraint tests (Section 4.3), forced-failure transaction test, explain checks of the search queries, restore rehearsal	TC-FR-05, TC-FR-30, TC-VFR-02, TC-VFR-14
AC-06 Payment Adapter	Contract of the four methods; error mapping; no card data crosses the interface	Contract tests on the fake; sandbox demonstration of one payment, one failure, one refund	TC-FR-13, TC-FR-16, TC-VFR-08
AC-07 Email Adapter	Contract of <code>send</code> ; error mapping; retry in the Notification module	Contract tests on the fake; one real email in the validation environment	TC-FR-01, TC-FR-03, TC-FR-14
AC-08 Health and Keep-Alive	Health endpoint reports database state; checks run at the required interval	Health tests with database up and down; uptime log review during the window	TC-VFR-09, PT-05

3.2 Module-level validation focus

Module	Main things to validate
BM-01 Authentication	Hash cost and salt; token signing, expiry and version check; lockout counter and unlock with a fake clock; single-use and expiry of verification and reset tokens; same response for known and unknown emails
BM-02 User and Profile	Address limit of 5 including concurrent adds; profile field validation; role grant and status change effects
BM-03 Catalog	Search fields and trigram search on seeded data (1, 2 and 3 or more characters, accents, capitals, ISBN fragments); filters, sorting and pagination; escaping of search text; category rename, duplicate name and delete rules; query plans use the search indexes
BM-04 Cart	Quantities limited to available units (stock minus reserved); summary arithmetic and rounding; cart survives logout
BM-05 Wishlist	Idempotent add; remove of absent book
BM-06 Order	Snapshots at order time; reservation at checkout and rollback when one line is short; idempotent confirmation; late payment after expiry; release on payment failure, cancellation and expiry (sweeper); status derivation; cancellation of unpaid and placed orders
BM-07 Payment	Calls only through the adapter; webhook signature check; refund path; no card fields in code, data or logs
BM-08 Review	Eligibility from delivered items; one review per customer and book; average rating recalculation on create and delete
BM-09 Seller	Application and approval states; owner filters on seller orders; item status transitions
BM-10 Inventory	Concurrent reservation never exceeds available units; finalise, release and restore leave stock and reserved consistent; stock cannot be set below reserved units; one low-stock alert per crossing of the threshold
BM-11 Admin	Self-suspension blocked; delegation to the owning modules; sessions invalidated on suspension
BM-12 Reporting	Totals equal hand-computed values on seeded orders; date range limits; cancelled orders excluded
BM-13 Notification	Retry with backoff and attempt limit; secrets not stored; in-app alert list and mark-as-read
BM-14 Media	Size, type and file-signature checks; image ownership; cache headers
BM-15 Platform and Security	Middleware order; CSRF; rate limits; redaction; error handler hides internals; health

Module	Main things to validate
BM-16 Book Management	Owner filters on listings; unique ISBN per seller; search fields regenerated when title, author or ISBN changes; image ownership; approval states

4. Design Validation

4.1 Module interface validation

Each interface of the Architecture document, Section 5, is validated at its boundary.

Interface	Caller to provider	How it is validated	Requirements and use cases
I-01	React SPA (ApiClient) to REST API Layer	Contract test of every endpoint against <code>openapi.yaml</code> (all TC-API groups): paths, methods, status codes, error object, cookie and CSRF header.	All FR; UC-01 to UC-25
I-02	Controller to Service	Controller tests with a mocked service: input mapping, status code mapping, error mapping; a controller test fails if a controller touches a repository.	All FR
I-03	Service to Repository	Repository tests on a test MongoDB replica set: filters, sort, pagination, owner filters, session use, duplicate-key mapping to codes.	All FR; VFR-14
I-04	AuthService to NotificationService	Unit test of the caller (AuthService) with the provider (NotificationService) mocked, checking arguments, results and error propagation; one integration test through both with a test database.	FR-01, FR-03; UC-04, UC-14, UC-25
I-05	AuthService to UserService	Unit test of the caller (AuthService) with the provider (UserService) mocked, checking arguments, results and error propagation; one integration test through both with a test database.	FR-01, FR-02, FR-03; VFR-04, VFR-07
I-06	CartService to InventoryService	Unit test of the caller (CartService) with the provider (InventoryService) mocked, checking arguments, results and error propagation; one integration test through both with a test database.	FR-09; UC-06
I-07	OrderService to CartService	Unit test of the caller (OrderService) with the provider (CartService) mocked, checking arguments, results and error propagation; one integration test through both with a test database.	FR-11, FR-12; UC-08
I-08	OrderService to PaymentService	Unit test of the caller (OrderService) with the provider (PaymentService) mocked, checking arguments, results and error propagation; one integration test through both with a test database.	FR-13, FR-16; UC-08, UC-09, UC-11
I-09	OrderService to InventoryService	Unit test of the caller (OrderService) with the provider (InventoryService) mocked, checking arguments, results and error propagation; one integration test through both with a test database.	FR-30, FR-16, FR-09; UC-08, UC-11
I-10	OrderService to NotificationService	Unit test of the caller (OrderService) with the provider (NotificationService) mocked, checking arguments, results and error propagation; one integration test through both with a test database.	FR-14; UC-08, UC-25
I-11	PaymentService to PaymentGateway adapter	Adapter contract tests on the fake gateway and, for the demo, the sandbox: create, verify, webhook verification, refund, error mapping; test that no method takes or returns card fields.	FR-13, FR-16; VFR-08
I-12	NotificationService to MailSender adapter	Adapter contract test on the console mailer and, for the demo, one real email; error mapping to <code>MailError</code> .	FR-01, FR-03, FR-14; UC-25
I-13	InventoryService to NotificationService	Unit test of the caller (InventoryService) with the provider (NotificationService) mocked, checking arguments, results and error propagation; one integration test through both with a test database.	FR-21; UC-17
I-14	ReviewService to OrderService / OrderRepository	Unit test of the caller (ReviewService) with the provider (OrderService / OrderRepository) mocked, checking arguments, results and error propagation; one integration test through both with a test database.	FR-17; UC-12
I-15	ReviewService to CatalogService	Unit test of the caller (ReviewService) with the provider (CatalogService) mocked, checking arguments, results and error propagation; one integration test through both with a test database.	FR-17, FR-27, FR-07
I-16	BookManagementService to MediaService	Unit test of the caller (BookManagementService) with the provider (MediaService) mocked, checking arguments, results and error propagation; one integration test through both with a test database.	FR-20; UC-16
I-17	BookManagementService to InventoryService	Unit test of the caller (BookManagementService) with the provider (InventoryService) mocked, checking arguments, results and error propagation; one integration test through both with a test database.	FR-20, FR-21; UC-16, UC-17

Interface	Caller to provider	How it is validated	Requirements and use cases
I-18	FulfilmentService to OrderService	Unit test of the caller (FulfilmentService) with the provider (OrderService) mocked, checking arguments, results and error propagation; one integration test through both with a test database.	FR-22, FR-15; UC-18
I-19	SellerService to UserService	Unit test of the caller (SellerService) with the provider (UserService) mocked, checking arguments, results and error propagation; one integration test through both with a test database.	FR-19; UC-21
I-20	AdminService to SellerService / BookManagementService	Unit test of the caller (AdminService) with the provider (SellerService / BookManagementService) mocked, checking arguments, results and error propagation; one integration test through both with a test database.	FR-25; UC-21
I-21	AdminService to UserService / AuthService	Unit test of the caller (AdminService) with the provider (UserService / AuthService) mocked, checking arguments, results and error propagation; one integration test through both with a test database.	FR-24; UC-20
I-22	AdminService to CatalogService / ReviewService / ReportingService	Unit test of the caller (AdminService) with the provider (CatalogService / ReviewService / ReportingService) mocked, checking arguments, results and error propagation; one integration test through both with a test database.	FR-26, FR-27, FR-28; UC-22, UC-23, UC-24
I-23	ReportingService to OrderRepository	Unit test of the caller (ReportingService) with the provider (OrderRepository) mocked, checking arguments, results and error propagation; one integration test through both with a test database.	FR-23, FR-28; UC-19, UC-24
I-24	authGuard (Platform) to UserService	authGuard tests: valid token, expired, tampered, wrong token version, suspended user, deleted user.	FR-02, FR-24, FR-29
I-25	Payment Gateway (external) to PaymentController	Webhook tests: valid signature accepted once, missing or wrong signature 401, replay changes nothing, unknown order ignored.	FR-13; UC-09
I-26	Uptime monitor (external) to HealthController	Health endpoint tests with the database up (200) and down (503); uptime log review in PT-05.	VFR-09
I-27	ReservationSweeper (Order module timer) to OrderService	Unit test of the caller (ReservationSweeper (Order module timer)) with the provider (OrderService) mocked, checking arguments, results and error propagation; one integration test through both with a test database.	FR-30, VFR-14, VFR-09
I-28	BookManagementService to CatalogService	Unit test of the caller (BookManagementService) with the provider (CatalogService) mocked, checking arguments, results and error propagation; one integration test through both with a test database.	FR-05, FR-20; UC-02, UC-16

4.2 API contract validation

Check	Method
openapi.yaml is valid	OpenAPI validator run in CI (TC-VFR-15)
Every endpoint of Software Design Document Section 6.3 is in the file, and nothing else is	Script comparing the endpoint table with the file and with the routes registered by the application
Responses match the schema	API tests validate each response body against the schema of its status code
Error shape	Every non-2xx response in the API tests has the uniform error object with a code from the catalogue (SDD Section 6.2)
Backward compatibility	From the first release of the API, a diff of the previous and current openapi.yaml is checked for removed or renamed fields (ABI wire contract, SDD Section 7)

4.3 Database constraint validation

Collection	Constraint or index	Validation
users	{ email: 1 } unique	Insert a duplicate; expect duplicate-key rejection mapped to the documented error code
auth_tokens	{ tokenHash: 1 } unique	Insert a duplicate; expect duplicate-key rejection mapped to the documented error code
auth_tokens	{ expiresAt: 1 } TTL (expireAfterSeconds: 0)	Insert a document with a past expiry; confirm it is removed by the TTL monitor and that code also rejects it before removal

Collection	Constraint or index	Validation
categories	{ name: 1 } unique, collation strength 2 (case-insensitive)	Insert a duplicate; expect duplicate-key rejection mapped to the documented error code
books	{ sellerId: 1, isbn: 1 } unique	Insert a duplicate; expect duplicate-key rejection mapped to the documented error code
carts	{ userId: 1 } unique	Insert a duplicate; expect duplicate-key rejection mapped to the documented error code
wishlists	{ userId: 1 } unique	Insert a duplicate; expect duplicate-key rejection mapped to the documented error code
orders	{ orderNumber: 1 } unique	Insert a duplicate; expect duplicate-key rejection mapped to the documented error code
payments	{ orderId: 1 } unique	Insert a duplicate; expect duplicate-key rejection mapped to the documented error code
payments	{ gatewayOrderId: 1 } unique	Insert a duplicate; expect duplicate-key rejection mapped to the documented error code
payments	{ gatewayPaymentId: 1 } unique, sparse	Insert a duplicate; expect duplicate-key rejection mapped to the documented error code
reviews	{ bookId: 1, userId: 1 } unique	Insert a duplicate; expect duplicate-key rejection mapped to the documented error code
seller_applications	{ userId: 1 } unique, partial (status = "pending")	Create a second pending record for the same user; expect duplicate-key rejection; after the first is decided, a new one is accepted
books	Schema validator: stock >= 0, price > 0	Direct write with stock -1 and price 0 is rejected by the database
books	Atomic decrement filter stock >= quantity	Concurrent decrement test: 50 parallel decrements of 1 on stock 10 give exactly 10 successes and stock 0 (TC-FR-30)
reviews	rating between 1 and 5	Direct write with rating 0 and 6 is rejected
users	Address list at most 5	Concurrent add of addresses never leaves more than 5 (TC-FR-18)
users	roles and status values	Write of an unknown role or status is rejected by the schema
orders	total = subtotal + tax + shippingFee; item status values	Unit test on creation; direct write of an unknown status is rejected
payments	No card fields; unique gatewayPaymentId	Schema inspection (strict mode rejects unknown fields); duplicate confirmation is idempotent

4.4 Authorization boundary validation

Boundary	Method
Role boundary (FR-29)	A table-driven API test takes every non-public endpoint from the RBAC matrix (SDD Section 6.6) and calls it with no session (expect 401), with each account type that is not allowed (expect 403): a customer-only account, a seller account (customer and seller roles) and an administrator account, as applicable, and, for state-changing calls, without a CSRF token (expect 403). A seller account must be accepted on Customer endpoints, because there is no Customer-versus-Seller exclusion (D-04)
Ownership boundary	For every endpoint marked "owner only", the second customer or second seller calls it with the first user's resource id and must receive 404 and no change in data
Seller visibility	In an order containing books of two sellers, each seller sees only their own items and no data of the other
Administrator boundary	Customer and seller tokens never receive data from /api/admin/*; user lists never contain password data
Session boundary	Tokens are rejected after expiry, logout, password reset and suspension (tokenVersion)

4.5 External service integration validation

Integration	Validation
Payment: create payment	Stock is reserved before the gateway is called; the fake gateway returns a reference; the order stores it; the amount sent equals the server-computed total
Payment: verify and confirm	Valid, invalid-signature, wrong-order and repeated confirmations; the reservation is finalised exactly once; confirmation after expiry reserves again or refunds; one sandbox payment in the validation environment
Payment: webhook	Valid signature accepted once; tampered or unsigned body rejected with 401; replay does not change the order

Integration	Validation
Payment: refund	Success marks the payment refunded; gateway error marks refund_pending and the order stays cancelled
Payment: failures	Gateway timeout or error returns 502 PAYMENT_GATEWAY_ERROR; the reservation is released and the order is PaymentFailed
Payment: failure, cancel and expiry	A failed payment, a cancelled unpaid order and an expired reservation each release the reserved units; stock and reserved return to their earlier values
Email	Verification, reset and order confirmation emails produced with correct links; send failure retried up to 3 times and recorded; order confirmation does not fail when email fails
Health monitor	Monitor receives 200 while the database is up and 503 when it is down

4.6 UI design validation

Check	Method
Every use case has a screen or email	Walkthrough of UC-01 to UC-25 against the screen table (Architecture Section 6.2)
Navigation matches roles	End-to-end tests log in as each role and check visible menu entries and blocked routes (S-30)
Screens use only documented endpoints	Script compares the API calls in the screen table with the endpoint table
Purchase in 6 steps or fewer (VFR-10)	Task walkthrough with at least 3 first-time users using the counting rule A-06

5. Updated Requirements Traceability Matrix

Columns: requirement, priority, use cases and the architecture component, design module and API endpoint columns added in Phase 2, and the test cases. The Phase 1 matrix (use cases, actors, test case) is kept unchanged in docs/phase-1/; the use case and test case columns here repeat it.

Req	Pri	Use case(s)	Architecture components	Design modules	API endpoints	Test cases
FR-01	M	UC-04, UC-25	AC-01 to AC-05, AC-07	BM-01, BM-13, FM-01	API-02 to API-04	TC-FR-01; TC-API-02; TC-API-03; TC-API-04
FR-02	M	UC-05	AC-01 to AC-05	BM-01, FM-01	API-05 to API-07	TC-FR-02; TC-API-05; TC-API-06; TC-API-07
FR-03	S	UC-14, UC-25	AC-01 to AC-05, AC-07	BM-01, BM-13, FM-01	API-08, API-09	TC-FR-03; TC-API-08; TC-API-09
FR-04	M	UC-01	AC-01 to AC-05	BM-03, FM-02	API-15	TC-FR-04; TC-API-15
FR-05	M	UC-02	AC-01 to AC-05	BM-03, FM-02	API-15	TC-FR-05; TC-API-15
FR-06	S	UC-02	AC-01 to AC-05	BM-03, FM-02	API-15, API-18	TC-FR-06; TC-API-15; TC-API-18
FR-07	M	UC-03	AC-01 to AC-05	BM-03, BM-14, FM-02	API-16, API-17, API-19	TC-FR-07; TC-API-16; TC-API-17; TC-API-19
FR-08	M	UC-06	AC-01 to AC-05	BM-04, FM-03	API-20 to API-23	TC-FR-08; TC-API-20; TC-API-21; TC-API-22; TC-API-23
FR-09	M	UC-06	AC-01 to AC-05	BM-04, BM-10, FM-03	API-21, API-22	TC-FR-09; TC-API-21; TC-API-22
FR-10	C	UC-07	AC-01 to AC-05	BM-05, FM-04	API-24 to API-26	TC-FR-10; TC-API-24; TC-API-25; TC-API-26
FR-11	M	UC-08	AC-01 to AC-05	BM-06, FM-05	API-12, API-27	TC-FR-11; TC-API-12; TC-API-27
FR-12	M	UC-08	AC-01 to AC-05	BM-04, BM-06, FM-03, FM-05	API-20, API-27	TC-FR-12; TC-API-20; TC-API-27
FR-13	M	UC-08, UC-09	AC-01 to AC-06	BM-06, BM-07, FM-05	API-27 to API-29	TC-FR-13; TC-API-27; TC-API-28; TC-API-29
FR-14	S	UC-08, UC-25	AC-01 to AC-05, AC-07	BM-06, BM-13, FM-05	API-28	TC-FR-14; TC-API-28
FR-15	M	UC-10	AC-01 to AC-05	BM-06, FM-06	API-30, API-31, API-43	TC-FR-15; TC-API-30; TC-API-31; TC-API-43
FR-16	S	UC-11	AC-01 to AC-06	BM-06, BM-07, BM-10, FM-06	API-32	TC-FR-16; TC-API-32
FR-17	S	UC-12	AC-01 to AC-05	BM-08, FM-07	API-17, API-33	TC-FR-17; TC-API-17; TC-API-33
FR-18	S	UC-13	AC-01 to AC-05	BM-02, FM-08	API-10 to API-14	TC-FR-18; TC-API-10 to 14 (5 endpoints)
FR-19	M	UC-15, UC-21	AC-01 to AC-05	BM-02, BM-09, BM-11, FM-08	API-34, API-35, API-50	TC-FR-19; TC-API-34; TC-API-35; TC-API-50
FR-20	M	UC-16	AC-01 to AC-05	BM-14, BM-16, FM-09	API-19, API-36 to API-39, API-41	TC-FR-20; TC-API-19 to 41 (6 endpoints)
FR-21	S	UC-17	AC-01 to AC-05, AC-07	BM-10, BM-13, FM-09	API-40, API-45, API-46	TC-FR-21; TC-API-40; TC-API-45; TC-API-46
FR-22	M	UC-18	AC-01 to AC-05	BM-09, FM-09	API-42, API-43	TC-FR-22; TC-API-42; TC-API-43
FR-23	C	UC-19	AC-01 to AC-05	BM-12, FM-09	API-44	TC-FR-23; TC-API-44
FR-24	M	UC-05, UC-20	AC-01 to AC-05	BM-01, BM-02, BM-11, FM-10	API-05, API-47, API-48	TC-FR-24; TC-API-05; TC-API-47; TC-API-48
FR-25	M	UC-21	AC-01 to AC-05	BM-09, BM-11, BM-16, FM-10	API-37, API-49 to API-54	TC-FR-25; TC-API-37 to 54 (7 endpoints)
FR-26	S	UC-23	AC-01 to AC-05	BM-03, BM-11, FM-10	API-18, API-55 to API-57	TC-FR-26; TC-API-18; TC-API-55; TC-API-56; TC-API-57

Req	Pri	Use case(s)	Architecture components	Design modules	API endpoints	Test cases
FR-27	S	UC-22	AC-01 to AC-05	BM-08, BM-11, FM-10	API-58, API-59	TC-FR-27; TC-API-58; TC-API-59
FR-28	C	UC-24	AC-01 to AC-05	BM-11, BM-12, FM-10	API-60	TC-FR-28; TC-API-60
FR-29	M	UC-05 to UC-24 (all role-restricted use cases)	AC-01 to AC-05	BM-01, BM-15, FM-11	All non-public endpoints (see Section 5 RBAC matrix)	TC-FR-29; TC-API-02 to TC-API-60 (authorization cases)
FR-30	M	UC-08	AC-01 to AC-05	BM-06, BM-10	API-27, API-28	TC-FR-30; TC-API-27; TC-API-28
VFR-01	M	UC-01, UC-02, UC-03	AC-01, AC-02, AC-05	BM-03, BM-15, FM-11	API-15, API-16, API-20	TC-VFR-01; TC-API-15; TC-API-16; TC-API-20
VFR-02	M	UC-01, UC-02	AC-02 to AC-05	BM-03, BM-15	API-15 to API-17	TC-VFR-02; TC-API-15; TC-API-16; TC-API-17
VFR-03	S	UC-01 to UC-25 (system-wide)	AC-02 to AC-05	BM-15	All endpoints (system-wide)	TC-VFR-03
VFR-04	M	UC-04, UC-05, UC-14	AC-03 to AC-05	BM-01	API-02, API-05, API-09	TC-VFR-04; TC-API-02; TC-API-05; TC-API-09
VFR-05	M	UC-01 to UC-25 (system-wide)	AC-01, AC-02, AC-06, AC-07	BM-15	All endpoints (system-wide)	TC-VFR-05
VFR-06	M	UC-01 to UC-25 (system-wide)	AC-01 to AC-04	BM-15	All endpoints (system-wide)	TC-VFR-06
VFR-07	S	UC-05	AC-02 to AC-05	BM-01, BM-15	API-05	TC-VFR-07; TC-API-05
VFR-08	M	UC-09	AC-01, AC-03, AC-05, AC-06	BM-07, BM-15	API-27 to API-29	TC-VFR-08; TC-API-27; TC-API-28; TC-API-29
VFR-09	S	UC-01 to UC-25 (system-wide)	AC-02, AC-08	BM-15	API-61	TC-VFR-09; TC-API-61
VFR-10	M	UC-01, UC-02, UC-03, UC-06, UC-08, UC-09	AC-01	FM-01, FM-02, FM-03, FM-05, FM-11	n/a (user interface or process requirement)	TC-VFR-10
VFR-11	S	UC-01, UC-02, UC-03, UC-06, UC-08, UC-09	AC-01	FM-01, FM-02, FM-03, FM-05, FM-11	n/a (user interface or process requirement)	TC-VFR-11
VFR-12	S	UC-01 to UC-25 (system-wide)	AC-01	FM-11	n/a (user interface or process requirement)	TC-VFR-12
VFR-13	M	UC-01 to UC-25 (system-wide)	AC-01 to AC-04	BM-15, FM-11	n/a (user interface or process requirement)	TC-VFR-13
VFR-14	S	UC-08, UC-09, UC-11	AC-03 to AC-06	BM-06, BM-07, BM-10	API-28, API-32, API-40	TC-VFR-14; TC-API-28; TC-API-32; TC-API-40
VFR-15	S	UC-01 to UC-25 (system-wide)	AC-02	BM-15	All endpoints (system-wide)	TC-VFR-15

Coverage statement. The matrix has 45 rows: 30 functional requirements and 15 non-functional requirements. Every row has at least one use case, at least one architecture component, at least one design module and at least one test case. Every Must requirement (26) is traced through all columns. Rows of requirements that concern the user interface or the development process (VFR-10 to VFR-13) have no API endpoint, which is stated in the row. Every endpoint API-01 to API-61 appears in at least one row or is covered by the system-wide rows, and has a TC-API group in Section 8. The matrix is generated and checked by script (DA-01 to DA-04).

6. Test Case Catalogue

Planned parent test cases of the 45 requirements. They are the Phase 1 test case IDs with their planned checks. Endpoint-level tests are in Section 8, security tests in Section 7 and performance tests in Section 9.

Test case	Requirement	Level	Key checks (planned)	Planned tools
TC-FR-01	FR-01	API, UI	Valid registration creates pending user and queues email; duplicate email (any case) rejected; password 7 chars rejected, 8 accepted; verification link activates account; expired link rejected.	Jest, Supertest, Cypress
TC-FR-02	FR-02	API, UI	Correct login sets cookie; wrong password returns 401; token stops working after 60 minutes (clock control) and after logout.	Supertest, Cypress
TC-FR-03	FR-03	API	Reset link works once; second use fails; link at 29 minutes works and at 31 minutes fails; all sessions invalidated.	Supertest
TC-FR-04	FR-04	API, UI	Seeded 45 books give pages of 20, 20, 5; page beyond last is empty; only approved listings appear.	Supertest, Cypress
TC-FR-05	FR-05	API	Substring match on title, author and ISBN, case-insensitive and accent-insensitive: 1 and 2 character terms use prefix mode, 3 or more characters use the trigram index; no result gives an empty list; regex and \$ characters are treated as text; search fields are updated after a title edit.	Supertest
TC-FR-06	FR-06	API, UI	Each filter alone and combined; sort orders verified on seeded data; invalid sort rejected.	Supertest, Cypress
TC-FR-07	FR-07	API, UI	Detail response and page contain every required field; unapproved book returns 404; out-of-stock status shown.	Supertest, Cypress
TC-FR-08	FR-08	API, UI	Add, change and remove lines; cart still present after logout and login; guest cannot use cart endpoints.	Supertest, Cypress
TC-FR-09	FR-09	API, UI	Available units are stock minus reserved. Stock 3: quantity 3 accepted, 4 rejected with message; two adds that exceed available stock together are rejected; units reserved by another customer's open checkout are not available.	Supertest, Cypress
TC-FR-10	FR-10	API, UI	Add, duplicate add (one entry), remove; wishlist survives re-login.	Supertest, Cypress
TC-FR-11	FR-11	API, UI	Order created with saved address and with entered address; neither or both rejected; another user's address rejected.	Supertest, Cypress
TC-FR-12	FR-12	Unit, API	Summary for known carts matches hand-calculated subtotal, tax, shipping, total in minor units; rounding cases.	Jest, Supertest
TC-FR-13	FR-13	API, UI, demo	Order stays PendingPayment until payment is confirmed; forged signature rejected; sandbox payment succeeds and the order becomes Placed; a failed or cancelled payment releases the reservation and leaves the order unconfirmed; a gateway error at checkout releases the reservation.	Supertest with mock gateway, Cypress, demo with sandbox
TC-FR-14	FR-14	API	Confirmation notification created and email sent within 60 seconds of confirmation (mock mailer timestamps); email failure does not fail the order and is retried.	Jest, Supertest
TC-FR-15	FR-15	API, UI	History shows only own confirmed orders newest first; statuses follow item updates; PendingPayment orders hidden.	Supertest, Cypress

Test case	Requirement	Level	Key checks (planned)	Planned tools
TC-FR-16	FR-16	API, UI	Cancel at Placed and Packed restores stock and starts the refund; cancel of an unpaid order releases the reservation and makes no refund call; Shipped and Delivered rejected; double cancel rejected.	Supertest, Cypress
TC-FR-17	FR-17	API, UI	Review accepted only after delivery; rating 0 and 6 rejected; second review rejected; average rating updated.	Supertest, Cypress
TC-FR-18	FR-18	API, UI	Profile edit persists; 5 addresses accepted and 6th rejected, also under concurrent requests; edit and delete own address only.	Supertest, Cypress
TC-FR-19	FR-19	API	Application pending until approved; seller endpoints return 403 before approval and succeed after; rejected applicant can apply again.	Supertest
TC-FR-20	FR-20	API, UI	Create, edit, remove own listing; another seller's listing returns 404; new listing hidden until approved; image rules enforced.	Supertest, Cypress
TC-FR-21	FR-21	API	Available 0 shows Out of stock (also while every unit is reserved); crossing the threshold at confirmation creates one alert; the alert can be read and marked read; stock cannot be set below the reserved units.	Supertest
TC-FR-22	FR-22	API, UI	Seller sees only own items of mixed orders; valid transitions accepted; skipping or reversing rejected; order status derived correctly.	Supertest, Cypress
TC-FR-23	FR-23	API	Report totals equal hand-computed values for seeded orders; cancelled orders excluded; invalid range rejected.	Supertest
TC-FR-24	FR-24	API	Suspended user cannot log in and an existing token stops working; reactivation restores login; admin cannot suspend self.	Supertest
TC-FR-25	FR-25	API	Approve and reject for applications and listings; decided items cannot be decided again; approved listing appears in catalog.	Supertest
TC-FR-26	FR-26	API	Add, rename, delete; duplicate name in different case rejected; delete with books rejected.	Supertest
TC-FR-27	FR-27	API	Review removal recalculates average rating; non-admin gets 403.	Supertest
TC-FR-28	FR-28	API	Totals and top-10 equal hand-computed values for seeded orders; empty range returns zeros.	Supertest
TC-FR-29	FR-29	API, security	Every protected endpoint tested with no token (401), wrong role (403) and wrong owner (404), generated from the endpoint table.	Supertest (table-driven)
TC-FR-30	FR-30	Integration	50 concurrent checkouts for a book with stock 10 give exactly 10 reservations and 40 rejections (409) with no payment started; confirming the 10 gives stock 0 and reserved 0, never negative; failed, abandoned and expired checkouts return reserved to 0; late payment after expiry re-reserves or is refunded.	Jest with replica-set MongoDB, k6
TC-VFR-01	VFR-01	Performance	Page-load time of catalog, book detail and cart measured while 100 virtual users run the browse scenario; 95th percentile at most 3 s.	Lighthouse CI or Playwright with k6
TC-VFR-02	VFR-02	Performance	GET /api/books with search and filters at 100 virtual users on 1,000 books and again on 10,000; 95th percentile at most 500 ms; query plans checked to use the search indexes.	k6, MongoDB explain
TC-VFR-03	VFR-03	Performance	100 concurrent virtual users running the mixed scenario for 10 minutes; error rate below 1%.	k6

Test case	Requirement	Level	Key checks (planned)	Planned tools
TC-VFR-04	VFR-04	Inspection, unit	Stored value is a bcrypt hash with cost 10 or more; no plaintext password in database, logs or responses.	Code review, Jest, database inspection
TC-VFR-05	VFR-05	Inspection, test	HTTP redirects to HTTPS; TLS 1.2 or higher only; cookies have the Secure attribute; HSTS header present.	curl, SSL scan, browser inspection
TC-VFR-06	VFR-06	Security	ZAP baseline scan has zero high or critical alerts; NoSQL injection, stored XSS and CSRF probes fail.	OWASP ZAP, Supertest, manual
TC-VFR-07	VFR-07	API	5 consecutive failures lock for 15 minutes; 5th success resets counter; unlock after 15 minutes (clock control).	Supertest
TC-VFR-08	VFR-08	Inspection, security	No card fields in schemas or code; payment requests and logs contain only gateway ids; log redaction test.	Code review, grep, Jest
TC-VFR-09	VFR-09	Analysis, test	During the evaluation window health checks run at 5 minutes or less; availability is successful checks divided by total checks and is at least 99%.	Uptime monitor, health endpoint
TC-VFR-10	VFR-10	UI, demo	Layout checked at 360, 768, 1280 and 1920 px; purchase completed in 6 steps or fewer by a first-time user.	Playwright viewport tests, task walkthrough
TC-VFR-11	VFR-11	UI	Lighthouse accessibility score 90 or higher on catalog, book detail, cart, checkout.	Lighthouse
TC-VFR-12	VFR-12	UI	Smoke flow (browse, login, cart, checkout in sandbox) on latest 2 versions of Chrome, Firefox, Edge, Safari.	Manual matrix, Playwright
TC-VFR-13	VFR-13	Inspection, test	Coverage report at least 70% lines; linter reports zero errors in CI.	Jest coverage, ESLint
TC-VFR-14	VFR-14	Integration, inspection	A forced failure during reservation or finalisation rolls the whole transaction back; reservation, finalisation, release and cancellation each leave stock and reserved consistent; daily backup configured and a restore rehearsed.	Jest, database provider settings
TC-VFR-15	VFR-15	Inspection	openapi.yaml validates, lists every endpoint of the endpoint table, and matches implemented routes.	OpenAPI validator, route listing script

7. Security Validation

7.1 Scope and approach

The security validation tests the controls of the Architecture document, Section 8, against the requirements VFR-04 to VFR-08 and FR-29, plus related abuse cases. It combines automated API tests, a dynamic scan with OWASP ZAP, dependency checks, code and data inspection, and manual probes. All of it runs against the validation environment or a local copy with test data only.

Pass criterion	Definition
Each ST case	Expected result observed
VFR-06	Zero high or critical findings in the ZAP baseline scan and in the authenticated API scan
Dependencies	No known high or critical vulnerability in direct production dependencies, or a documented and approved exception
Defects	Any failed ST case is a defect with severity; critical and high must be fixed before exit

7.2 Security test cases

ID	Requirement	Case	Method	Expected result
ST-01	VFR-04	Password storage: register a user, then inspect the database and logs	Database inspection, log search	Only a bcrypt hash with cost 10 or higher is stored; the password does not appear in the database, logs or any response
ST-02	VFR-04, FR-02	User enumeration at login: wrong password versus unknown email	API test	Identical status, code and message (401 INVALID_CREDENTIALS)
ST-03	VFR-07	Brute force: 5 consecutive failed logins, then a correct login, then wait 15 minutes (fake clock)	API test	5th failure locks the account; correct password gives 423 with Retry-After while locked; login works after 15 minutes; counter resets on success
ST-04	FR-02	Token tampering: change payload, change algorithm to none, sign with another key	API test	401 for every tampered token
ST-05	FR-02, FR-24	Token lifetime: use a token after 60 minutes, after logout, after password reset, after suspension	API test with fake clock	401 or 403 in every case
ST-06	FR-29	Vertical privilege escalation: customer-only token on seller and admin endpoints; seller token (customer and seller roles) on admin endpoints; administrator token on customer and seller endpoints	Table-driven API test from the RBAC matrix	403 on every one
ST-07	FR-29	Horizontal escalation (IDOR): second user requests first user's order, address, listing, order item, notification	API test	404 and no data change
ST-08	FR-29	Mass assignment: send roles , status , sellerId , price of someone else, passwordHash in registration, profile and listing bodies	API test	Fields rejected or ignored; stored values unchanged
ST-09	VFR-06	NoSQL injection: { "\$ne": "" } as email or password; q[\$regex]=.* and \$where in query strings	API test, ZAP	400 VALIDATION_ERROR; no extra data returned; login not bypassed
ST-10	VFR-06	Pattern abuse in search: very long text, regex metacharacters, catastrophic patterns	API test with time limit	Text longer than 100 characters rejected; metacharacters matched as text; response time within VFR-02
ST-11	VFR-06	Stored XSS: script and event-handler payloads in review comment, store name, listing description, address fields, profile name	End-to-end test, ZAP	Payload displayed as text, never executed; Content-Security-Policy header present
ST-12	VFR-06	Reflected XSS: payloads in query strings and in route parameters echoed by error messages	API and end-to-end test, ZAP	Not executed; error messages do not echo raw input unescaped
ST-13	VFR-06	CSRF: state-changing request without token, with a wrong token, and a cross-site form post that carries the cookie only	API test, manual probe	403 CSRF_INVALID; no data change

ID	Requirement	Case	Method	Expected result
ST-14	VFR-05	Transport: open the site over HTTP; connect with TLS 1.0, 1.1 and 1.2; inspect cookie flags and HSTS	curl, SSL scanner, browser tools	HTTP redirected to HTTPS; TLS below 1.2 refused; Secure flag and HSTS header present
ST-15	VFR-06	Security headers: Content-Security-Policy, X-Content-Type-Options, frame protection, Referrer-Policy	API test, ZAP	All present with restrictive values
ST-16	VFR-08	Card data: search schemas, code, fixtures and logs for card-like fields; send a test card number in request bodies	Code review, grep, Jest	No card fields exist; the number is rejected or ignored, not stored and redacted from logs
ST-17	VFR-08, FR-13	Webhook forgery and replay: missing signature, tampered body, replayed valid event	API test	401 for missing or bad signature; replay changes nothing
ST-18	FR-13, FR-12	Amount tampering: client sends its own price or total; price edited by the seller between cart and checkout	API test	Server uses current prices and computes the total; client values ignored
ST-19	FR-30	Overselling race: many concurrent checkouts for the last copies, followed by confirmations, failures and expiries	Integration test, k6 (PT-04)	reserved never exceeds stock and stock is never below zero; a rejected checkout is told before any payment starts
ST-20	FR-17	Review abuse: review without a delivered purchase; second review of the same book	API test	403 NOT_ELIGIBLE; 409 ALREADY_REVIEWED
ST-21	FR-03	Reset token: reuse, use after 30 minutes, guess, request for unknown email, many requests	API test, entropy review	Single use; expires after 30 minutes; at least 128 bits random; stored hashed; same response for unknown email; rate limited
ST-22	FR-01	Verification token: reuse, expiry, tamper	API test	Rejected with TOKEN_INVALID_OR_EXPIRED
ST-23	VFR-06	API abuse: exceed authentication rate limit; exceed global limit; oversized JSON body; malformed JSON; very deep objects	API test, k6	429 RATE_LIMITED; 413 or 400; service stays responsive
ST-24	FR-20	Upload abuse: wrong file signature, renamed executable, SVG with script, path traversal in file name, file over 2 MB	API test	400 INVALID_FILE or 413 FILE_TOO_LARGE; nothing stored
ST-25	VFR-06	Dependency vulnerabilities	Dependency audit of lock files (server and client)	No high or critical in direct production dependencies, or approved exception
ST-26	VFR-06	Dynamic scan: ZAP baseline against the validation environment, and an API scan using <code>openapi.yaml</code> , authenticated as customer, seller and administrator	OWASP ZAP	Zero high or critical findings
ST-27	VFR-04, VFR-08	Secrets: scan repository history for keys and passwords; check <code>.env</code> is ignored; compare environment variables with the inventory	Secret-scanning tool or grep, review	No secret in the repository; every variable documented
ST-28	VFR-06	Error handling: provoke 500 errors and database errors	API test	Generic message; no stack trace, query or configuration in the response
ST-29	FR-24	Suspension: suspended user login and existing session; administrator suspends self	API test	Login 403; session 401; self-suspension 409 CANNOT_MODIFY_SELF
ST-30	FR-24, FR-25	Audit trail: login failures, lockout, role change, suspension, approvals, refunds	Log inspection	Entries contain actor id and time and no secrets
ST-31	FR-29	Dual role: a seller account calls Customer endpoints and Seller endpoints; no endpoint rejects a user because the user is also a seller	API test	Accepted on both; roles are read from the database on every request
ST-32	FR-30, VFR-06	Reservation abuse: start checkouts and never pay, to hold stock; many checkouts by one customer	API test with fake clock, k6	One open checkout per customer; reservations expire after 15 minutes and are released by the sweeper; checkout is rate limited

7.3 Abuse and negative cases summary

Area	Abuse cases covered
Authentication and sessions	ST-02 to ST-05, ST-21, ST-22, ST-29
Authorization	ST-06 to ST-08, ST-31
Injection and XSS	ST-09 to ST-12
CSRF and transport	ST-13 to ST-15
Payment	ST-16 to ST-19
Business logic	ST-18 to ST-20, ST-32
API abuse and uploads	ST-23, ST-24
Supply chain and secrets	ST-25, ST-27

8. API Validation

8.1 Approach

Each of the 61 endpoints has a test group TC-API-nn with the cases below. The same table-driven test runner is used for the cases that repeat across endpoints.

Cases that apply to every endpoint:

Case	Expected result
Valid request	Documented success status and a body that matches the schema
Missing required field	400 VALIDATION_ERROR naming the field
Wrong type or out-of-range value	400 VALIDATION_ERROR
Unknown extra field	Rejected or ignored; never stored
Boundary values	Lowest and highest allowed value accepted; one beyond rejected
Malformed or empty JSON	400
Malformed resource id in the path	400 or 404
No session on a protected endpoint	401 UNAUTHENTICATED
Session with the wrong role	403 FORBIDDEN
Missing CSRF token on a state-changing request	403 CSRF_INVALID
Another user's resource	404 NOT_FOUND
Error body	Uniform error object with a catalogued code

8.2 Test data

Seed data from Section 2.3 plus: a book with stock 3, an out-of-stock book, a pending, a rejected and a removed listing, a delivered order, a shipped order, a placed order, a pending seller application, a suspended user and a locked user.

8.3 Endpoint test table

The table adds the endpoint-specific cases to the common ones above. "Error responses to trigger" lists every error code the endpoint can return, so each must be provoked at least once.

Test case	Endpoint	Positive	Error responses to trigger	Invalid input, missing data, boundary cases	Authentication and authorization cases
TC-API-01	GET /api/auth/csrf-token	200 with documented body	none specific	Token differs per session; token rotates after login	public
TC-API-02	POST /api/auth/register	201 with documented body	400 VALIDATION_ERROR; 409 EMAIL_TAKEN; 429 RATE_LIMITED	password of 7 and 8 and 73 chars; duplicate email in different case; missing name	missing CSRF token: 403
TC-API-03	POST /api/auth/verify-email	200 with documented body	400 VALIDATION_ERROR; 400 TOKEN_INVALID_OR_EXPIRED	expired token; reused token; random token	missing CSRF token: 403
TC-API-04	POST /api/auth/resend-verification	200 with documented body	400 VALIDATION_ERROR; 429 RATE_LIMITED	unknown email returns the same 200; already verified account	missing CSRF token: 403
TC-API-05	POST /api/auth/login	200 with documented body	400 VALIDATION_ERROR; 401 INVALID_CREDENTIALS; 403 EMAIL_NOT_VERIFIED; 403 ACCOUNT_SUSPENDED; 423 ACCOUNT_LOCKED; 429 RATE_LIMITED	5th and 6th consecutive failure; success on 5th resets counter; suspended user with correct password; lock expiry after 15 minutes	missing CSRF token: 403
TC-API-06	POST /api/auth/logout	200 with documented body	401 UNAUTHENTICATED	old token rejected after logout	no or expired session: 401; missing CSRF token: 403
TC-API-07	GET /api/auth/me	200 with documented body	401 UNAUTHENTICATED	expired token (after 60 minutes); suspended user with a still-valid token	no or expired session: 401
TC-API-08	POST /api/auth/forgot-password	200 with documented body	400 VALIDATION_ERROR; 429 RATE_LIMITED	unknown email returns the same 200; repeated requests are rate limited	missing CSRF token: 403
TC-API-09	POST /api/auth/reset-password	200 with documented body	400 VALIDATION_ERROR; 400 TOKEN_INVALID_OR_EXPIRED	token at 29 and 31 minutes; second use of the same token; weak password length 7	missing CSRF token: 403
TC-API-10	GET /api/profile	200 with documented body	401 UNAUTHENTICATED	seller account (also holds customer role) allowed; administrator forbidden	no or expired session: 401; role not allowed (administrator account): 403

Test case	Endpoint	Positive	Error responses to trigger	Invalid input, missing data, boundary cases	Authentication and authorization cases
TC-API-11	PATCH /api/profile	200 with documented body	400 VALIDATION_ERROR	phone of 6 and 16 digits; attempt to send email or roles field is ignored or rejected	no or expired session: 401; role not allowed (administrator account): 403; missing CSRF token: 403
TC-API-12	POST /api/profile/addresses	201 with documented body	400 VALIDATION_ERROR; 409 ADDRESS_LIMIT	5th address accepted, 6th rejected; concurrent adds do not exceed 5	no or expired session: 401; role not allowed (administrator account): 403; missing CSRF token: 403
TC-API-13	PATCH /api/profile/addresses/:addressId	200 with documented body	400 VALIDATION_ERROR; 404 NOT_FOUND	address of another user returns 404	no or expired session: 401; role not allowed (administrator account): 403; missing CSRF token: 403; other owner: 404
TC-API-14	DELETE /api/profile/addresses/:addressId	204 with documented body	404 NOT_FOUND	address of another user returns 404; orders keep their address snapshot	no or expired session: 401; role not allowed (administrator account): 403; missing CSRF token: 403; other owner: 404
TC-API-15	GET /api/books	200 with documented body	400 VALIDATION_ERROR	q of 1, 2 and 3 characters (prefix mode and trigram mode); mixed case and accented text; ISBN fragment; q with regex or \$ characters is matched as text; page 0 and beyond last page; minPrice greater than maxPrice; 20 vs 21 results	public
TC-API-16	GET /api/books/:bookId	200 with documented body	404 NOT_FOUND	pending, rejected or removed listing returns 404; malformed id returns 400	public
TC-API-17	GET /api/books/:bookId/reviews	200 with documented body	400 VALIDATION_ERROR; 404 NOT_FOUND	book without reviews returns an empty page	public
TC-API-18	GET /api/categories	200 with documented body	none specific	empty list; newly renamed category visible immediately	public
TC-API-19	GET /api/images/:imageId	200 with documented body	404 NOT_FOUND	unknown id returns 404	public
TC-API-20	GET /api/cart	200 with documented body	401 UNAUTHENTICATED	empty cart; book removed or out of stock since it was added; totals computed to 2 decimals	no or expired session: 401; role not allowed (administrator account): 403
TC-API-21	POST /api/cart/items	200 with documented body	400 VALIDATION_ERROR; 404 BOOK_NOT_FOUND; 409 INSUFFICIENT_STOCK	stock 3 and quantity 4; add 2 then 2 with stock 3; quantity 0 and 51	no or expired session: 401; role not allowed (administrator account): 403; missing CSRF token: 403
TC-API-22	PATCH /api/cart/items/:bookId	200 with documented body	400 VALIDATION_ERROR; 404 ITEM_NOT_IN_CART; 409 INSUFFICIENT_STOCK	quantity equal to stock accepted, stock+1 rejected	no or expired session: 401; role not allowed (administrator account): 403; missing CSRF token: 403

Test case	Endpoint	Positive	Error responses to trigger	Invalid input, missing data, boundary cases	Authentication and authorization cases
TC-API-23	DELETE /api/cart/items/:bookId	200 with documented body	404 ITEM_NOT_IN_CART	removing the last item returns an empty cart	no or expired session: 401; role not allowed (administrator account): 403; missing CSRF token: 403
TC-API-24	GET /api/wishlist	200 with documented body	401 UNAUTHENTICATED	books that became unavailable are marked unavailable	no or expired session: 401; role not allowed (administrator account): 403
TC-API-25	PUT /api/wishlist/items/:bookId	200 with documented body	404 BOOK_NOT_FOUND	adding the same book twice leaves one entry	no or expired session: 401; role not allowed (administrator account): 403; missing CSRF token: 403
TC-API-26	DELETE /api/wishlist/items/:bookId	204 with documented body	none specific	removing a book that is not present is accepted	no or expired session: 401; role not allowed (administrator account): 403; missing CSRF token: 403
TC-API-27	POST /api/orders	201 with documented body	400 VALIDATION_ERROR; 409 INSUFFICIENT_STOCK; 502 PAYMENT_GATEWAY_ERROR	empty cart; both or neither address field; address of another user; two customers reserve the last copy (one 201, one 409); gateway failure releases the reservation; a second checkout closes the first open one; reservation expires after the configured time	no or expired session: 401; role not allowed (administrator account): 403; missing CSRF token: 403
TC-API-28	POST /api/orders/:orderId/payment/confirm	200 with documented body	400 VALIDATION_ERROR; 404 NOT_FOUND; 400 PAYMENT_VERIFICATION_FAILED; 409 ORDER_NOT_PAYABLE; 409 ORDER_FAILED_REFUNDED; 502 PAYMENT_GATEWAY_ERROR	forged signature; payment for another order; second call after success; confirmation after the reservation expired (re-reserve succeeds, or the order fails with refund); confirm after cancel	no or expired session: 401; role not allowed (administrator account): 403; missing CSRF token: 403; other owner: 404
TC-API-29	POST /api/payments/webhook	200 with documented body	401 INVALID_SIGNATURE	tampered body; missing signature; replayed event; event for an unknown order	bad signature: 401
TC-API-30	GET /api/orders	200 with documented body	400 VALIDATION_ERROR	customer sees only own orders	no or expired session: 401; role not allowed (administrator account): 403
TC-API-31	GET /api/orders/:orderId	200 with documented body	404 NOT_FOUND	another customer's order returns 404	no or expired session: 401; role not allowed (administrator account): 403; other owner: 404
TC-API-32	POST /api/orders/:orderId/cancel	200 with documented body	404 NOT_FOUND; 409 ORDER_NOT_CANCELLABLE	cancel at Placed and Packed succeeds; cancel of an unpaid order releases the reservation and calls no refund; Shipped fails; double cancel fails; refund call fails (order cancelled, refundStatus refund_pending)	no or expired session: 401; role not allowed (administrator account): 403; missing CSRF token: 403; other owner: 404
TC-API-33	POST /api/books/:bookId/reviews	201 with documented body	400 VALIDATION_ERROR; 404 NOT_FOUND; 403 NOT_ELIGIBLE; 409 ALREADY_REVIEWED	rating 0 and 6; script tag in comment; review before delivery; second review of the same book	no or expired session: 401; role not allowed (administrator account): 403; missing CSRF token: 403

Test case	Endpoint	Positive	Error responses to trigger	Invalid input, missing data, boundary cases	Authentication and authorization cases
TC-API-34	POST /api/seller/applications	201 with documented body	400 VALIDATION_ERROR; 409 APPLICATION_EXISTS; 409 ALREADY_SELLER	second application while one is pending; apply after rejection allowed; apply as an existing seller	no or expired session: 401; role not allowed (administrator account): 403; missing CSRF token: 403
TC-API-35	GET /api/seller/applications/me	200 with documented body	404 NOT_FOUND	status after approve and reject	no or expired session: 401; role not allowed (administrator account): 403
TC-API-36	GET /api/seller/books	200 with documented body	400 VALIDATION_ERROR	seller sees none of another seller's listings	no or expired session: 401; role not allowed (customer-only account; administrator account): 403; other owner: 404
TC-API-37	POST /api/seller/books	201 with documented body	400 VALIDATION_ERROR; 409 ISBN_EXISTS_FOR_SELLER	invalid ISBN check digit; price 0; 4 images; image of another seller; duplicate ISBN for same seller	no or expired session: 401; role not allowed (customer-only account; administrator account): 403; missing CSRF token: 403
TC-API-38	PATCH /api/seller/books/:bookId	200 with documented body	400 VALIDATION_ERROR; 404 NOT_FOUND	another seller's listing returns 404; attempt to set status or sellerId is rejected	no or expired session: 401; role not allowed (customer-only account; administrator account): 403; missing CSRF token: 403; other owner: 404
TC-API-39	DELETE /api/seller/books/:bookId	204 with documented body	404 NOT_FOUND	another seller's listing returns 404; removed listing disappears from catalog, carts and wishlists views	no or expired session: 401; role not allowed (customer-only account; administrator account): 403; missing CSRF token: 403; other owner: 404
TC-API-40	PATCH /api/seller/books/:bookId/inventory	200 with documented body	400 VALIDATION_ERROR; 404 NOT_FOUND; 409 STOCK_BELOW_RESERVED	stock set to 0 shows Out of stock; stock below reserved units rejected; available 0 while units are reserved shows Out of stock; stock below threshold creates one alert; empty body	no or expired session: 401; role not allowed (customer-only account; administrator account): 403; missing CSRF token: 403; other owner: 404
TC-API-41	POST /api/seller/uploads/images	201 with documented body	400 INVALID_FILE; 413 FILE_TOO_LARGE	exactly 2 MB and 2 MB + 1 byte; renamed .exe; SVG; empty file	no or expired session: 401; role not allowed (customer-only account; administrator account): 403; missing CSRF token: 403
TC-API-42	GET /api/seller/orders	200 with documented body	400 VALIDATION_ERROR	items of other sellers in a mixed order are never returned	no or expired session: 401; role not allowed (customer-only account; administrator account): 403; other owner: 404
TC-API-43	PATCH /api/seller/orders/:orderId/items/:itemId/status	200 with documented body	400 VALIDATION_ERROR; 404 NOT_FOUND; 409 INVALID_STATUS_TRANSITION	skip Packed; go backwards; update another seller's item; update a Cancelled item	no or expired session: 401; role not allowed (customer-only account; administrator account): 403; missing CSRF token: 403; other owner: 404
TC-API-44	GET /api/seller/reports/sales	200 with documented body	400 VALIDATION_ERROR; 400 INVALID_DATE_RANGE	from equals to; from after to; 367-day range; cancelled orders excluded	no or expired session: 401; role not allowed (customer-only account; administrator account): 403; other owner: 404

Test case	Endpoint	Positive	Error responses to trigger	Invalid input, missing data, boundary cases	Authentication and authorization cases
TC-API-45	GET /api/notifications	200 with documented body	400 VALIDATION_ERROR	only the caller's alerts	no or expired session: 401; role not allowed (customer-only account; administrator account): 403; other owner: 404
TC-API-46	PATCH /api/notifications/:notificationId/read	200 with documented body	404 NOT_FOUND	another user's alert returns 404; marking twice is accepted	no or expired session: 401; role not allowed (customer-only account; administrator account): 403; missing CSRF token: 403; other owner: 404
TC-API-47	GET /api/admin/users	200 with documented body	400 VALIDATION_ERROR	customer or seller token returns 403; passwordHash never present in response	no or expired session: 401; role not allowed (customer-only account; seller account): 403
TC-API-48	PATCH /api/admin/users/:userId/status	200 with documented body	400 VALIDATION_ERROR; 404 NOT_FOUND; 409 CANNOT_MODIFY_SELF	suspend then login fails; suspended user with old token rejected; reactivate then login works; suspend self	no or expired session: 401; role not allowed (customer-only account; seller account): 403; missing CSRF token: 403
TC-API-49	GET /api/admin/seller-applications	200 with documented body	400 VALIDATION_ERROR	default filter is pending	no or expired session: 401; role not allowed (customer-only account; seller account): 403
TC-API-50	POST /api/admin/seller-applications/:applicationId/approve	200 with documented body	404 NOT_FOUND; 409 NOT_PENDING	approve twice; approve rejected application; applicant can use seller endpoints only after approval	no or expired session: 401; role not allowed (customer-only account; seller account): 403; missing CSRF token: 403
TC-API-51	POST /api/admin/seller-applications/:applicationId/reject	200 with documented body	400 VALIDATION_ERROR; 404 NOT_FOUND; 409 NOT_PENDING	missing reason; reject approved application	no or expired session: 401; role not allowed (customer-only account; seller account): 403; missing CSRF token: 403
TC-API-52	GET /api/admin/books	200 with documented body	400 VALIDATION_ERROR	default filter is pending	no or expired session: 401; role not allowed (customer-only account; seller account): 403
TC-API-53	POST /api/admin/books/:bookId/approve	200 with documented body	404 NOT_FOUND; 409 NOT_PENDING	approved listing appears in GET /api/books; approve twice	no or expired session: 401; role not allowed (customer-only account; seller account): 403; missing CSRF token: 403
TC-API-54	POST /api/admin/books/:bookId/reject	200 with documented body	400 VALIDATION_ERROR; 404 NOT_FOUND; 409 NOT_PENDING	missing reason; rejected listing stays hidden	no or expired session: 401; role not allowed (customer-only account; seller account): 403; missing CSRF token: 403
TC-API-55	POST /api/admin/categories	201 with documented body	400 VALIDATION_ERROR; 409 CATEGORY_EXISTS	Fiction and fiction; empty name; 61 chars	no or expired session: 401; role not allowed (customer-only account; seller account): 403; missing CSRF token: 403

Test case	Endpoint	Positive	Error responses to trigger	Invalid input, missing data, boundary cases	Authentication and authorization cases
TC-API-56	PATCH /api/admin/categories/:categoryId	200 with documented body	400 VALIDATION_ERROR; 404 NOT_FOUND; 409 CATEGORY_EXISTS	rename to existing name; rename to same name	no or expired session: 401; role not allowed (customer-only account; seller account): 403; missing CSRF token: 403
TC-API-57	DELETE /api/admin/categories/:categoryId	204 with documented body	404 NOT_FOUND; 409 CATEGORY_IN_USE	delete empty category; delete category with a book	no or expired session: 401; role not allowed (customer-only account; seller account): 403; missing CSRF token: 403
TC-API-58	GET /api/admin/reviews	200 with documented body	400 VALIDATION_ERROR	filter by book and by low rating	no or expired session: 401; role not allowed (customer-only account; seller account): 403
TC-API-59	DELETE /api/admin/reviews/:reviewId	204 with documented body	404 NOT_FOUND	delete then average rating changes; delete twice returns 404	no or expired session: 401; role not allowed (customer-only account; seller account): 403; missing CSRF token: 403
TC-API-60	GET /api/admin/reports/platform	200 with documented body	400 VALIDATION_ERROR; 400 INVALID_DATE_RANGE	range with no orders returns zeros and an empty list; exactly 10 top books; cancelled orders excluded	no or expired session: 401; role not allowed (customer-only account; seller account): 403
TC-API-61	GET /api/health	200 with documented body	503 UNHEALTHY	database stopped returns 503; response does not leak configuration or versions	public

9. Performance Validation

9.1 Approach

Performance tests run against the validation environment (same configuration as the final demo). The load generator runs from a separate machine. The rate limiter is raised through the environment variables `RATE_LIMIT_GLOBAL` and `RATE_LIMIT_AUTH` for the test only, because all virtual users share one client address. The tests below define the conditions; the thresholds are the Phase 1 requirement values and are written into the test scripts so that a run passes or fails automatically.

9.2 Tests

ID	Requirement	Scenario and conditions	Measurement	Pass criterion
PT-01	VFR-02	100 virtual users for 10 minutes after a 1-minute ramp-up; 1,000 approved books; 70% of requests <code>GET /api/books</code> with varied search text, filters and sorts, 30% <code>GET /api/books/:bookId</code> ; think time 1 to 3 seconds	Response time of <code>GET /api/books</code>	95th percentile at most 500 ms
PT-02	VFR-01	While PT-01 runs, load the catalog (S-01), book details (S-02) and cart (S-08) in a browser at least 30 times each from a fixed machine using one fixed throttling profile (A-07)	Page load time per page	95th percentile at most 3 seconds for each page
PT-03	VFR-03	Mixed scenario with 100 virtual users for 10 minutes: 60% browse, 20% search, 10% cart changes, 5% login, 5% complete checkout with the fake gateway	Share of failed requests (5xx, timeouts, unexpected 4xx)	Below 1%
PT-04	FR-30, VFR-03	Stock contention: 100 virtual users each start a checkout for the same book with stock 10; the customers who obtained a reservation then pay with the fake gateway (a mix of success, failure and abandonment)	Reservations granted, final stock and reserved, 5xx count	Exactly 10 reservations are granted and 90 are rejected with 409 before any payment starts; after payments and expiry, stock equals 10 minus the confirmed orders and reserved is 0; never negative; no 5xx
PT-05	VFR-09	Availability: the uptime monitor calls <code>GET /api/health</code> every 5 minutes or less during the whole evaluation window; keep-alive configuration inspected	Successful checks divided by total checks	At least 99%; no check failed because the service was asleep
PT-06	VFR-02	Repeat PT-01 with 10,000 approved books to check that search time stays within the criterion as the catalogue grows	Response time of <code>GET /api/books</code>	95th percentile at most 500 ms; if it is missed, apply the contingency options of the Software Design Document, Section 4.4.5, and repeat

9.3 Result recording

Each run records: date, commit identifier, environment, data size, scenario parameters, measured percentiles and error rate, and pass or fail. Results will be added to the Validation Report in Phase 4. None exist yet.

10. Design Acceptance Criteria

The architecture and design are ready for Phase 3 when all criteria below are met.

ID	Criterion	How it is checked
DA-01	Every FR and VFR traces to at least one use case, architecture component, design module and test case	Script over the RTM reports zero gaps
DA-02	Every use case UC-01 to UC-25 appears in at least one screen or email, one module and one requirement	Script over screens, module table and requirement table
DA-03	Every endpoint in the endpoint table is in <code>openapi.yaml</code> , the file validates, and every endpoint has a TC-API group	Validator and comparison script
DA-04	Every endpoint has an access rule that matches the RBAC matrix, and every role-restricted use case maps to role-restricted endpoints	Script over endpoint table and use case table
DA-05	Every collection in the data dictionary appears in the ER diagram and the class diagram, and every query used by an endpoint has a supporting index	Review against the endpoint table
DA-06	Every module has an owner; every team member owns at least one backend and one frontend module and leads three Phase 2 items	Check of the division-of-work tables
DA-07	All design decisions and assumptions D-01 to D-15 and ambiguities A-01 to A-14 are reviewed and each is recorded as approved or changed; assumption D-05 (login requires a verified email) is confirmed or replaced	Team review record
DA-08	Every module, endpoint and entity named in a diagram exists in the tables and the reverse	Script comparing diagram sources with the tables
DA-09	VFR-04 to VFR-08 and FR-29 each have a mechanism in the architecture, a place in the design and at least one security test	Section 7 table and Architecture Section 8
DA-10	Provider decisions (hosting, payment, email, uptime monitor, database tier) are made, or a mock fallback is recorded for each	TBD list in the Architecture document
DA-11	The team walks the purchase flow, the seller approval flow and the cancellation flow through the sequence diagrams and finds no missing step	Walkthrough record
DA-12	Diagram sources (PlantUML) and images are in the repository and match the text	File check and DA-08
DA-13	Phase 1 files are unchanged	Comparison of file hashes with the Phase 1 commit
DA-14	The reservation lifecycle (reserve, finalise, release, expire, late payment, cancel) appears consistently in the architecture, data model, API, sequence and activity diagrams and the test plan	Walkthrough and a script comparing the diagrams with the tables

11. Assumptions and Open Items

The design decisions and assumptions D-01 to D-15, ambiguities A-01 to A-14 and TBD items of the Architecture document, Section 11, apply here. Items that most affect validation: A-06 (how purchase steps are counted), A-07 (definition of page load time), A-09 (evaluation window dates), D-05 (login requires a verified email, an assumption to confirm), A-13 (reservation hold time), the choice of load, scan and monitoring tools, and the payment and email providers, which decide whether sandbox demonstrations are possible.